

TASK 4

ANFAL TARIQ

Cybersecurity

REPORT:

Security Mistakes Made by the Company and Employees

The foundation of this breach rests on a series of overlapping administrative and human errors.

- First and foremost, the company failed to enforce a robust authentication framework. Allowing employees to use "simple passwords" indicates a complete absence of password complexity rules, rotation schedules, or blacklisting of common credentials.
- Secondly, the organization exhibited a reckless disregard for network security by granting employees unrestricted access to corporate systems via public Wi-Fi networks without any protective overlay.
- Thirdly, the company operates a "bring your own device" (BYOD) environment without centralized control; accessing sensitive customer data from unmanaged personal devices creates an enormous attack surface, as these endpoints lack standardized antivirus, firewalls, and patch levels.
- Finally, the organization lacked proactive monitoring capabilities. The fact that unusual login activity was merely "noticed" rather than immediately flagged and blocked by automated systems demonstrates a passive, reactive security posture rather than a proactive defensive strategy.

Type of Cyber Risks Involved

This situation encapsulates several high-level risk categories.

- **Operational risk** is present because the breach disrupts normal business functions and erodes consumer trust.
- **Regulatory and compliance risk** looms large, as the leakage of customer personally identifiable information (PII) exposes the company to severe fines under frameworks like GDPR or CCPA.
- **Reputational risk** threatens the company's long-term viability, as customers will likely defect to more secure competitors.
- **Financial risk** materializes not only through potential legal penalties but also through the costly incident response, forensic investigations, and mandatory credit monitoring services that must now be provided to affected clients.

Identification of Threats

Based on the scenario, the following five distinct cyber threats have materialized or are imminent:

1. **Man-in-the-Middle (MITM) Attacks on Public Networks:** Public Wi-Fi hotspots are inherently unencrypted. Attackers can position themselves between the employee's device and the website to intercept unencrypted login credentials in real-time.

2. **Evil Twin Rogue Access Points:** Cybercriminals often deploy fraudulent Wi-Fi networks with legitimate-sounding names (e.g., "Cafe_Free_WiFi"). Employees unknowingly connect to these malicious access points, allowing attackers to capture every keystroke and session cookie.
3. **Credential Stuffing and Brute-Force Attacks:** Because employees rely on simple, easily guessed passwords, attackers can leverage automated scripts to rapidly test millions of common password combinations against the company's login portal until they achieve unauthorized access.
4. **Endpoint Malware and Keyloggers:** The use of diverse, unmanaged personal devices increases the risk that an employee's smartphone or laptop has pre-existing malware. A keylogger silently records all keystrokes, transmitting the employee's username and password directly to the attacker's command-and-control server.
5. **Session Hijacking via Stolen Cookies:** Once an employee successfully authenticates, the website generates a session token. If the connection over public Wi-Fi lacks sufficient encryption (like TLS), attackers can sniff this token and import it into their own browser, effectively bypassing the need for a password entirely.

Proposed Practical Solutions

To address these critical vulnerabilities, the company must immediately deploy the following six countermeasures:

1. **Enforce a Strict, Modern Password Policy:** Move beyond basic requirements. Implement a policy mandating passphrases of at least 16 characters that include uppercase, lowercase, numbers, and special symbols. Crucially, integrate a dynamic password blacklist that automatically rejects any password found in known data breach dumps (using services like "Have I Been Pwned" API).
2. **Mandate Multi-Factor Authentication (MFA) Without Exception:** Implement 2FA for every single employee login, regardless of location. By requiring a one-time time-based code generated via an authenticator app or a hardware security key, the company ensures that even if a password is compromised, the attacker cannot progress past the login barrier.
3. **Prohibit Public Wi-Fi and Deploy a Mandatory Corporate VPN:** Establish a strict policy forbidding access to company resources over unsecured networks. Provide employees with a company-approved, always-on VPN solution with split-tunneling disabled. This encrypts all traffic from the device to the corporate gateway, rendering public network sniffing useless.
4. **Implement Endpoint Protection and Mobile Device Management (MDM):** Deploy an MDM solution for all devices accessing the company environment—whether corporate-owned or personal. This allows the IT team to enforce screen locks, push critical security patches, remotely wipe lost devices, and ensure that anti-malware definitions are continuously updated.
5. **Adopt Continuous Log Monitoring and Anomaly Detection:** Upgrade from manual log reviews to a Security Information and Event Management (SIEM) system powered by User and Entity Behavior Analytics (UEBA). This system must be configured to flag "impossible travel" (e.g., a login from the US and another from Russia within five minutes) and automatically freeze the account until verified.

6. **Conduct Regular, Interactive Security Awareness Training:** Transform annual compliance checklists into engaging, monthly micro-training sessions. Include realistic phishing simulations and specific modules on the dangers of public Wi-Fi, how to identify rogue access points, and the critical importance of reporting lost or stolen devices immediately.

Immediate Security Improvement Plan

To transition from a reactive state to a secure posture, leadership must authorize the following urgent action roadmap:

- **Step 1: Crisis Containment and Credential Reset (Hours 0-2).** Immediately force a global password reset for all employees. Terminate all active web sessions and API tokens to invalidate the attacker's current access. Simultaneously, isolate the affected web server from the production environment to prevent lateral movement while preserving forensic data.
- **Step 2: Forensic Triage and Legal Notification (Hours 0-24).** Engage an external digital forensics team to analyze server logs and determine the precise attack vector and the full scope of exfiltrated customer data. Simultaneously, consult legal counsel to prepare the mandatory breach notification letters for affected customers and regulatory authorities.
- **Step 3: Emergency Patch and Firewall Hardening (Day 1-2).** Ensure the web application is fully patched, focusing on any known vulnerabilities related to authentication bypass. Update Web Application Firewall (WAF) rules to aggressively throttle login attempts and block IP addresses originating from the attacker's known geographic regions.
- **Step 4: Expedited Deployment of Multi-Factor Authentication (Day 2-3).** Fast-track the rollout of MFA for every employee. Initially, utilize SMS-based verification (as it is the quickest to deploy) while simultaneously preparing more secure authenticator-app options for a permanent replacement by the end of the month.
- **Step 5: Issuance of VPN Credentials and Policy Enforcement (Week 1).** Provision VPN licenses for all staff and publish a new, strictly enforced "Acceptable Use Policy" that explicitly bans access to customer data over public Wi-Fi without the corporate VPN. Block all direct port 80/443 traffic to the internal application, allowing only VPN-originated traffic.
- **Step 6: Launch "Security Refresher" Bootcamp (Week 1-2).** Conduct mandatory, in-person or virtual security seminars covering the recent breach details (lessons learned) and new security protocols. This human-centric approach is critical to ensuring employees understand the "why" behind the new restrictive policies.
- **Step 7: Establish Ongoing Governance and Review (Week 2-4).** Finally, schedule a recurring monthly security review meeting. At this stage, finalize a comprehensive Incident Response Playbook, ensure backups are immutable and tested, and set a quarterly external penetration test to continuously validate the security improvements.